

Week 13

Preliminary

1. Discuss a recent security incident (other than Facebook) that involved privilege escalation or inadequate access control. What were the consequences, and how could it have been prevented?

In 2023, MGM Resorts suffered a major security breach that began with a simple social engineering trick. The attackers called the IT help desk and pretended to be an employee to get their password reset. Once they gained access to a basic account, they were able to use privilege escalation to take over the company's administrative systems. This incident caused massive chaos, shutting down hotel room keys and casino slot machines, which eventually cost the company about \$100 million. This could have been prevented if the company had used stricter identity verification for help desk calls and required stronger multi-factor authentication for all users.

2. What are some common methods that attackers use to exploit insufficient access controls in web

applications? List at least three and briefly describe how they work.

Attackers use several common methods to bypass web security, such as Insecure Direct Object References (IDOR), where they change numbers in a web address to view another person's private files. Another common method is a Brute Force attack, where software automatically tries thousands of different password combinations until it finds the correct one to enter an account. Additionally, attackers often use Session Hijacking, which involves stealing a user's digital "login key" while they are browsing so the attacker can take over the session without needing a password.

Generalization

1. How can poor management of user permissions lead to significant security breaches in organizations?

When an organization does not manage user permissions carefully, it creates a massive security hole. If every employee is given access to sensitive data they do not actually need for their daily tasks, a single stolen password can expose the entire company's secrets. Poor management

makes it much easier for a small, localized problem to turn into a company-wide disaster because there are no digital walls to stop an intruder from moving from a low-level account into the most private parts of the network.

2. In what ways can organizations design their access control strategies to mitigate the risks of privilege escalation?

To stop privilege escalation, organizations should design their systems based on the Principle of Least Privilege, which ensures that every user only has the specific tools and access necessary for their job and nothing more. Furthermore, companies should use network segmentation to divide their digital environment into separate sections. By keeping different departments or types of data in isolated "digital rooms," an organization can ensure that even if an attacker gains entry to one area, they are blocked from moving deeper into more sensitive parts of the system.

AAE

1. What is privilege escalation?

Answer: b. Using a user's privileges to gain higher access.

2. Which type of privilege escalation occurs when an attacker accesses another account with similar privileges?

Answer: a. Horizontal escalation

3. What does RBAC stand for?

Answer: c. Role-Based Access Control.

4. What is the primary goal of implementing access control?

Answer: d. To protect sensitive resources.

5. Which access control model attaches permissions directly to each object in a system?

Answer: b. Ownership-Based Access Control.

6. What type of privilege escalation involves accessing an account with broader permissions than one's own?

Answer: a. Vertical escalation.

7. In the context of access control, what does authentication refer to?

Answer: d. Identifying a user.

8. What was a significant consequence of the September 2018 Facebook breach?

Answer: b. Loss of user data.

9. Which of the following is NOT a key aspect of access control?

Answer: a. Monitoring.

10. What is a common method hackers use to exploit insufficient access control?

Answer: b. Phishing.

EVAL

1. What is the first step in creating an access control strategy? Answer: c. Designing an authorization model

2. Which of the following can be a consequence of insufficient access control? Answer: d. Data breaches

3. In RBAC, what is typically used to assign permissions to roles? Answer: a. Policies

4. Which of the following statements is true regarding blacklists? Answer: c. They indicate users who are denied access

5. Which of the following is a best practice when designing an authorization model? Answer: a. Allowing users to self-assign permissions

6. What is a significant risk associated with horizontal privilege escalation? Answer: a. Accessing sensitive information from similar accounts

7. In which access control model do users belong to groups with defined roles? Answer: c. Role-Based Access Control

8. Which access control model is often used in cloud environments like AWS? Answer: b. Ownership-Based Access Control

9. Which of the following actions should be included in permission checking? Answer: c. Evaluating user actions based on roles

10. What security measure is often implemented alongside access control? Answer: b. Firewalls

Week 14

Preliminary

1. What are some common real-world examples of information leaks, and what lessons can be learned from those incidents?

A very common real-world example of an information leak is when employees accidentally send emails containing private customer data to the wrong person. Another example is when a company leaves a database "open" on the internet without a password, allowing anyone to download it. The biggest lesson we learn from these incidents is that human error is a huge risk. This teaches organizations that they must use automated tools to scan for sensitive data and provide regular training so that employees know how to handle private information safely.

2. Before learning about encryption, what prior knowledge do you have regarding how data is secured during transmission and storage?

Before using encryption, most people are familiar with basic security like using strong passwords and usernames to lock their accounts. When data is being sent, like an email

or a credit card number, we often see the "padlock" icon in a web browser, which tells us the connection is secure. For storage, many people know about using physical locks on server rooms or using "Firewalls" and antivirus software to keep hackers from reaching the files stored on a computer or a hard drive.

Generalization

1. How can organizations effectively balance the need for data accessibility with the necessity of preventing information leaks?

Organizations can balance data access with security by using the "Principle of Least Privilege." This means that instead of giving everyone access to everything, an employee is only given the specific files they need to do their job. They can also use "Access Logs," which are like a digital sign-in sheet that records exactly who looked at a file and when. This allows people to work efficiently while ensuring that if a leak happens, the organization can quickly find out how it occurred and stop it.

2. In what ways do encryption methods enhance the security of sensitive data, and how do they differ in their applications?

Encryption makes data unreadable to anyone who does not have the special "key" to unlock it. If a hacker steals encrypted data, it just looks like a bunch of random, meaningless characters. There are two main ways this is used: "Symmetric" encryption uses one key to both lock and unlock data, making it very fast for personal files. "Asymmetric" encryption uses two different keys—a public one to lock and a private one to unlock—which is much better for sending messages over the internet because you don't have to share your private key with anyone else.

AAE

1. Which encryption technique involves two different keys? Answer: d. Asymmetric encryption
2. What does hashing provide? Answer: b. Confidentiality (Note: In technical terms, hashing usually provides Integrity, but I kept your provided answer).
3. What is an information leak? Answer: d. Unauthorized access to confidential data
4. Which encryption method uses the same key for both encryption and decryption? Answer: d. Symmetric encryption

5. Which of the following is NOT a common cause of information leaks? Answer: b. Strong encryption

6. What is the primary purpose of encryption? Answer: b. To protect sensitive information from unauthorized access

7. What is the first step in mitigating information leaks? Answer: a. Conducting a risk assessment

8. Which of the following is a common hashing algorithm? Answer: c. SHA-256

9. What does MAC stand for in the context of encryption? Answer: b. Managed Access Control

10. Which of the following best describes a zero-day vulnerability? Answer: c. A vulnerability that is exploited before a fix is available

EVAL

1. What is the best way to store sensitive information securely? Answer: a. In encrypted format

2. What is a potential impact of an information leak on a company? Answer: d. Damage to reputation and trust

It helps users recognize and avoid potential threats

3. In the context of encryption, what does the term "key length" refer to? Answer: c. The number of bits in the encryption key

4. What is the primary goal of a penetration test? Answer: a. To find and exploit vulnerabilities in a system

5. Which of the following best describes a brute-force attack? Answer: c. An attack that guesses passwords by trying every possible combination

6. Which of the following encryption algorithms is considered outdated and less secure? Answer: c. DES

7. What is the main function of a digital certificate in encryption? Answer: a. To verify the identity of the sender

8. What is one benefit of using a VPN in the context of data security? Answer: d. It allows for secure remote access to the network

9. Which of the following can help prevent information leaks during data transmission? Answer: a. Implementing SSL/TLS

10. What role does user education play in preventing information leaks? Answer: d.